

RISK MANAGEMENT POLICY

Version 1.0

Revision Date: August 18, 2026

Contact: security@prompthalo.com



DOCUMENT INFORMATION

Document Family	Governance, Ethics, and Security
Document Title	Risk Management Policy
Document ID	POL-RSK-001
Current Version	1.0
Approved Date	August 18, 2026
Approved By	Information Security Steering Committee
Effective Date	August 18, 2026
Next Review Date	August 18, 2027
Classification	Internal
Document Owner	Chief Executive Officer — Accountable Party
Prepared By	Security Officer
Review Cycle	Annual, or upon material change
Supersedes	N/A
Audience	All personnel, including employees and contractors

APPROVERS AND OWNERS

Name	Role	Information Security Role	Signature	Date
Madhuri Chandoor	Approver	CEO and Founder		August 18, 2026
Praveen Sharma	Owner / Author	Fractional CISO/Security Officer		August 18, 2026

COMPLIANCE

This Policy is authorized by the Information Security Policy (POL-ISP-001) and supports the SOC 2 Trust Services Criteria CC1.2, CC3.1, CC3.2, CC3.3, CC3.4 and CC5.1, and GDPR Articles 32 and 35. It is written for a ten-person company and uses one register, one annual assessment and a short list of triggers.

DOCUMENT VALIDITY

This document is valid only in its published electronic form in the PromptHalo Technologies policy repository. Printed or locally saved copies are uncontrolled and must be verified against the published version before use. This document is classified Internal and may not be distributed outside PromptHalo Technologies or its authorized clients without the written approval of the Security Officer.

TABLE OF CONTENTS

1 OVERVIEW AND PURPOSE	5
2 SCOPE	5
3 ROLES AND DEFINITIONS.....	5
4 TERMINOLOGY	5
5 RISK APPETITE	6
6 SCORING	6
7 THE REGISTER	6
8 THE ANNUAL ASSESSMENT	7
9 REASSESSMENT TRIGGERS	7
10 FROM RISK TO CONTROL.....	8
11 RECORDS	8
12 EXCEPTIONS.....	8
13 REFERENCE	8
14 DOCUMENT POLICY HISTORY.....	8

1 Overview and Purpose

PromptHalo Technologies (“the Company”) identifies what could go wrong, decides what to do about it, and records both. This Policy says how, on a scale that a ten-person team can sustain.

There is one register and one assessment a year, plus a reassessment when something on the trigger list at Section 9 happens. Risk work that is not written down is not risk work, but the writing should take an afternoon, not a quarter.

2 Scope

This Policy covers risks to the security of Company and client information: risks arising in the Company itself, in its vendors and sub-processors, and in the AI models and agents it runs.

Where a requirement here would take longer to perform than the risk it addresses would cost, the lighter form is used and the reason is recorded. Proportionality is the rule, not an exception to it.

3 Roles and Definitions

1. "The Company" refers to PromptHalo Technologies.
2. The CEO or, in their absence, the Security Officer (the “Accountable Party”) owns this policy, oversees its implementation and enforcement, and may delegate specific duties to a designee. [SOC 2: CC1.3]
3. The Information Security Steering Committee approves this policy and reviews it at least annually. [SOC 2: CC1.2, CC5.3]
4. The Accountable Party maintains the register, runs the annual assessment, and decides treatment. Risk acceptances are approved by the CEO. [SOC 2: CC3.2, CC1.3]
5. Each risk has a named owner. At the Company's size that will usually be the same small number of people and naming them is still the point — an unowned risk is one nobody is watching. [SOC 2: CC3.2]

4 Terminology

The following terms have the meanings given below wherever they appear in this policy.

1. **Accountable Party** — the CEO or, in their absence, the Security Officer, who owns this policy.
2. **Confidential information** — information classified Confidential or Restricted under the Data Classification Policy, including customer data.
3. **Control** — an activity, automated or manual, performed on a defined cadence that produces evidence it occurred.
4. **Deficiency** — a control that is absent, not operating as described, or not producing evidence.
5. **Information Security Steering Committee** — the Company's oversight body for information security. At the Company's current size, the Committee comprises the CEO, and every reference

in this policy to a decision, approval, review or report of the Committee is satisfied by a dated written record made or confirmed by the CEO; a formal meeting is not required. [SOC 2: CC1.2, CC1.3]

6. **Inherent risk** — the level of a risk before any treatment is applied.
7. **Personnel** — employees, officers, contractors, consultants, interns and temporary workers of the Company.
8. **Residual risk** — the level of a risk after treatment, which is what the Company actually carries.
9. **Risk appetite** — the level at or below which a risk may be accepted without treatment, stated at Section 5.
10. **Security Officer** — the individual accountable for day-to-day operation of the security program.
11. **Significant change** — a change meeting the trigger criteria at Section 9 that requires risk reassessment.
12. **Subservice organization** — a third party whose controls the Company relies upon and which is carved out of the Company's report.
13. **Treatment** — what the Company decides to do about a risk: reduce, transfer, avoid or accept.

5 Risk Appetite

1. Risks scoring at or below the accepted level may be carried without treatment, and the decision is recorded in the register. Risks above it require a treatment plan with an owner and a target date. [SOC 2: CC3.1, CC3.2]
2. Anything that would expose client information, breach a client commitment, or stop the service for more than a day sits above the appetite regardless of score. [SOC 2: CC3.1]
3. A risk accepted above the appetite is approved by the CEO and recorded with the rationale, the decider, the date and an expiry. An acceptance with no expiry is a decision nobody will revisit. [SOC 2: CC3.2]

6 Scoring

1. Likelihood and impact are each scored on a five-point scale and multiplied. The scales and what each point means are recorded once in the register rather than restated here, so that scoring stays consistent between assessments. [SOC 2: CC3.2]
2. Each risk carries an inherent score, the treatment decision, and a residual score. The residual score is the one the Company is carrying and is the one reported. [SOC 2: CC3.2]

7 The Register

1. One register holds every risk: what it is, who owns it, the inherent score, the treatment decision, the residual score, and the date last reviewed. A spreadsheet is sufficient and no tool is required. [SOC 2: CC3.2, CC2.1]

2. Identification covers the Company itself, its vendors and sub-processors, and the AI models and agents it runs. Vendors are risk-assessed before onboarding and reassessed annually where they process client information. [SOC 2: CC3.2, CC9.2]
3. Treatment progress is reviewed at the annual assessment and whenever a target date passes. A plan whose date has passed without comment is a deficiency, not a delay. [SOC 2: CC3.2]

8 The Annual Assessment

One sitting a year, recorded in the Annual Control Environment Assessment where that is the natural place for a conclusion. It covers the sections below and takes an afternoon.

1. The register is reviewed in full: new risks added, closed risks closed, scores revisited where something changed. [SOC 2: CC3.2]
2. Fraud is considered explicitly: fraudulent reporting, misappropriation of assets, circumvention of controls, insider misuse of privileged access — including standing access held inside customer environments — and the potential for management override given a single approver. Where no case arose in the year, a nil return is recorded; the absence of cases is the evidence and an empty section is not. [SOC 2: CC3.3, CC1.1]
3. The absence of oversight independent of security operations is carried as a recorded risk with an annual review date, rather than left as an unstated feature of the Company's size. [SOC 2: CC1.2, CC1.3]
4. External change is reviewed: the threat landscape, applicable regulation, and AI-specific developments including provider terms, model deprecations and published attack techniques. The sources relied on are the ones named in the external information source list under the Information Security Policy, so this is checkable rather than an assertion of vigilance. Where nothing changed the Company's position, that is recorded. [SOC 2: CC3.4, CC2.1]

9 Reassessment Triggers

Between annual assessments, these oblige a reassessment. The list is short so that it gets read.

1. A new product, service or model in the path of what the Company delivers; a new customer segment or a client with materially different obligations; a new vendor or sub-processor handling client information; a material change to the system boundary; or a significant incident. [SOC 2: CC3.4]
2. When a trigger fires, the assessment is refreshed for what changed — not repeated in full — and the change is approved before it goes live. [SOC 2: CC3.4, CC8.1]
3. Closing a trigger includes updating the System Security Plan and the asset inventory where the boundary moved. [SOC 2: CC3.4, CC2.1]

10 From Risk to Control

1. Controls are selected to treat identified risks, and the mapping from risk to control is recorded so that both directions can be read: what treats this risk, and what risk does this control exist for. [SOC 2: CC5.1]
2. Selection considers where the risk arises and combines preventing it with detecting it. A risk treated only by detection is one the Company has decided to notice rather than avoid, and that is a choice worth making deliberately. [SOC 2: CC5.1]
3. A control is not adopted because a framework lists it. A control that treats no identified risk is removed rather than carried, because every control carried is one that must be operated and evidenced. [SOC 2: CC5.1, CC5.3]

11 Records

1. The risk register, including the scoring scales and the appetite statement. [SOC 2: CC3.2]
2. The annual assessment record, including the fraud section and its nil return where applicable. [SOC 2: CC3.3]
3. Risk acceptances with rationale, decider, date and expiry. [SOC 2: CC3.2]
4. Reassessment records where a trigger fired. [SOC 2: CC3.4]
5. The risk-to-control mapping. [SOC 2: CC5.1]

12 Exceptions

Where a requirement of this Policy cannot be met proportionately, the position is recorded by the Accountable Party with the compensating measure and a review date. Where no exceptions are in force, that is recorded affirmatively at the annual review.

13 Reference

1. SOC 2 Trust Services Criteria, Security category [CC1.2, CC3.1, CC3.2, CC3.3, CC3.4, CC5.1]
2. POL-ISP-001 Information Security Policy [SOC 2: CC5.3, CC2.1]
3. FRM-CE-001 Annual Control Environment Assessment [SOC 2: CC4.1]
4. POL-COC-001 Code of Conduct [SOC 2: CC1.1]
5. POL-VM-001 Vendor Management Policy [SOC 2: CC9.2]
6. POL-AI-001 Artificial Intelligence Governance Policy [SOC 2: CC3.4]
7. POL-CM-001 Change Management Policy [SOC 2: CC8.1]
8. EU General Data Protection Regulation, Articles 32 and 35

14 Document Policy History

Version	Date	Description
1.0	August 18, 2026	Initial policy release

133